

MK FRAUD READINESS · COMPREHENSIVE

DIAGNOSIS

Fraud Readiness Strategy and Control Blueprint

Strategy, exposure interpretation and target-state control
design

Kestrel Industrial Supply (Pty) Ltd

Assessment reference: MKFRS-2026-95B3815A0C

Generated 12 August 2026

Purpose, scope and how to read this blueprint

A management blueprint for understanding the recorded position, deciding treatment, building the target control environment and monitoring progress.

Product proposition

- Diagnosis: where the organisation stands.
- Interpretation: where exposure concentrates and how scenarios may develop.
- Design: what management should build, decide and monitor.

Boundary

This report provides strategic fraud-risk analysis and control design based on management's recorded Fraud Readiness assessment responses. It does not independently verify operating effectiveness.

The automated product is generated from assessment results alone. Customer upload, human approval and assurance workflow are outside this product boundary.

Current readiness position

The deterministic score and maturity position are carried through from the recorded assessment without narrative adjustment.

Readiness 55 / 100	Final maturity Developing	Exposure Not scored	Coverage 100% 8 critical · 0 major gaps
---	---	---	--

Reading rule

Use the score to describe the recorded position. Use the blueprint to decide how management will improve the position.

Where exposure concentrates

The exposure story is concentrated in the material findings, risk pathways and interactions that connect multiple control conditions.

PRIORITY FINDING	RISK IMPLICATION	CURRENT POSITION	TREATMENT DIRECTION
Fraud Leadership and Governance: Management owns fraud risk, while internal audit or assurance functions provide independent review where they exist.	This recorded weakness affects a methodology hard gate and must be remediated before relying on the aggregate maturity result.	Partially designed — Some elements exist, but implementation is incomplete, inconsistent or not evidenced.	The CEO and audit-committee chair must approve a RACI that assigns control operation to management and risk owners, reserves independent testing and unrestricted reporting for internal audit or equivalent assurance, and requires annual conflict review; the company secretary retains the approved RACI and minutes.
Fraud Incident Response: Evidence linked to suspected fraud is identified, preserved and handled appropriately.	This recorded weakness affects a methodology hard gate and must be remediated before relying on the aggregate maturity result.	Partially designed — Some elements exist, but implementation is incomplete, inconsistent or not evidenced.	The investigation lead opens an evidence register for every material case; trained custodians identify sources, create forensic copies or sealed originals, record hashes/seal numbers, collector/time/location and every transfer, store evidence in access-controlled repositories, and escalate any custody break immediately to Legal.
Digital and Identity Fraud Access to sensitive digital systems, administrator rights and confidential data is restricted and reviewed.	This recorded weakness affects a methodology hard gate and must be remediated before relying on the aggregate maturity result.	Partially designed — Some elements exist, but implementation is incomplete, inconsistent or not evidenced.	IT Security maintains a complete privileged-account register, links each human and service account to an owner and approved justification, enforces separate named admin identities and MFA, records privileged sessions, and sends the full population quarterly to system owners and Risk for independent keep/remove certification; removals close within 24 hours for leavers and five business days otherwise.
Fraud Detection Capability: The organisation monitors transactions or operational activity for unusual patterns, anomalies or red flags.	This recorded weakness affects a methodology hard gate and must be remediated before relying on the aggregate maturity result.	Partially designed — Some elements exist, but implementation is incomplete, inconsistent or not evidenced.	The monitoring owner must define red-flag indicators per material process — duplicate payments, round-value patterns, out-of-hours activity, unusual volume by user, adjustments reversing prior entries, and supplier or customer concentration — run them against the complete transaction population on a set rhythm, and route output into the exception queue with designated control owners and SLAs; coverage against the process fraud maps is reported to the fraud forum.
Continuous Improvement and Fraud Risk Monitoring: The organisation periodically reviews its fraud risks and control environment.	This recorded weakness affects a methodology hard gate and must be remediated before relying on the aggregate maturity result.	Partially designed — Some elements exist, but implementation is incomplete, inconsistent or not evidenced.	The Head of Risk must run a scheduled review that revisits the fraud risk assessment for continued relevance, confirms for each key control that it still has a named owner and is still operating by sampling recent evidence rather than accepting attestation, records any control that has lapsed or degraded, and reports a consolidated risk and control position to the governing body with owned remediation actions and due dates.

What leadership should do now

Leadership should focus on the decisions that unlock accountable ownership, target-state design and implementation sequencing.

Accountable Executive Mandate

DECISION REQUIRED

Approve accountable executive mandates and escalation authority for priority remediation.

WHY NOW

Hard-gate, governance and maturity-limiting controls require authority to allocate resources and resolve blockers.

CONSEQUENCE OF DELAY

Priority controls remain ownerless or blocked and the maturity reading remains constrained.

Risk Acceptance Or Remediation

DECISION REQUIRED

Choose and record remediation rather than passive acceptance for Critical and High risks.

WHY NOW

Plausible consequence pathways require an explicit leadership treatment decision.

CONSEQUENCE OF DELAY

Known risk pathways remain untreated without a documented acceptance basis.

Control Design Standard

DECISION REQUIRED

Approve exact question-level control designs as the minimum implementation standard.

WHY NOW

Functions need one design baseline rather than independent interpretations of the findings.

CONSEQUENCE OF DELAY

Partial or inconsistent designs fail to address the causal pathway.

Management test

Can the accountable executive name the owner, target period, first deliverable and failure response for each priority?

Readiness profile across the assessment

The profile below is a management view of the analytical universe. Domain-level scores remain traceable to the score run.

DOMAIN	RECORDED SCORE	WEIGHT	CRITICAL GAPS
Fraud Leadership and Governance	62	12%	1
Fraud Risk Identification	46	12%	1
Operational Fraud Controls	71	14%	0
Fraud Detection Capability	40	14%	1
Fraud Incident Response	60	10%	1
Whistleblowing and Reporting Culture	76	6%	0
Third-Party and Supply Chain Fraud Risk	54	10%	0
Digital and Identity Fraud Risk	48	12%	3
Fraud Culture and Awareness	60	5%	0
Continuous Improvement and Fraud Risk Monitoring	44	5%	1

Systemic themes across the control environment

Systemic themes are the patterns that make isolated improvements less durable.

How the themes interact

INTERPRETATION

The target state must address interactions, not only individual questions.

INTERACTION	ENABLED PATHWAY	LEADERSHIP RESPONSE
-------------	-----------------	---------------------

Design principle

Treat cross-domain dependencies as implementation dependencies: ownership, population, data, escalation and oversight must connect.

Material finding 1

INTERPRETATION

Domain

Fraud Leadership and Governance

D1-Q04

Materiality

maturity_constraint

Priority 2400

Target period

30
days

DIAGNOSIS

Management-versus-assurance role separation was self-assessed as "Partially designed" (Some elements exist, but implementation is incomplete, inconsistent or not evidenced; normalised score 40/100). This is self-reported and requires the listed operating evidence before it can be treated as verified.

WHY IT MATTERS

This recorded weakness affects a methodology hard gate and must be remediated before relying on the aggregate maturity result.

FRAUD MECHANISM

When assurance owns the control it later reviews, gaps can be accepted or missed without an independent challenge.

LIKELY IMPACTS

Indirect -- unresolved control gaps can remain unfunded or unchallenged.; Accountability and independent challenge may be unclear.

INTERPRETATION

Management-versus-assurance role separation was self-assessed as "Partially designed" (Some elements exist, but implementation is incomplete, inconsistent or not evidenced; normalised score 40/100). This is self-reported and requires the listed operating evidence before it can be treated as verified.

RECOMMENDED CONTROL

The CEO and audit-committee chair must approve a RACI that assigns control operation to management and risk owners, reserves independent testing and unrestricted reporting for internal audit or equivalent assurance, and requires annual conflict review; the company secretary retains the approved RACI and minutes.

EFFECTIVENESS MEASURE

No key fraud control is both operated and independently certified by the same accountable function.

ESCALATION THRESHOLD

Any assurance reviewer assigned operational ownership of the control under review.

Management implication

MK Fraud Readiness · Comprehensive blueprint · Confidential

The CEO and audit-committee chair must approve a RACI that assigns control

Material finding 2

INTERPRETATION

Domain	Materiality	Target period	Owner
Fraud Incident Response D5-Q05	control_failure Priority 2150	60 days	Gene Coun / COC

DIAGNOSIS

Fraud evidence preservation and chain of custody was self-assessed as "Partially designed" (Some elements exist, but implementation is incomplete, inconsistent or not evidenced; normalised score 40/100). This is self-reported and requires the listed operating evidence before it can be treated as verified.

WHY IT MATTERS

This recorded weakness affects a methodology hard gate and must be remediated before relying on the aggregate maturity result.

FRAUD MECHANISM

Uncontrolled collection or transfer can alter, lose or contaminate evidence, undermining investigation, recovery or disciplinary action.

LIKELY IMPACTS

Indirect -- delayed response or compromised evidence increases investigation and recovery cost.; Containment, investigation and legal action may be weakened.

INTERPRETATION

Fraud evidence preservation and chain of custody was self-assessed as "Partially designed" (Some elements exist, but implementation is incomplete, inconsistent or not evidenced; normalised score 40/100). This is self-reported and requires the listed operating evidence before it can be treated as verified.

RECOMMENDED CONTROL

The investigation lead opens an evidence register for every material case; trained custodians identify sources, create forensic copies or sealed originals, record hashes/seal numbers, collector/time/location and every transfer, store evidence in access-controlled repositories, and escalate any custody break immediately to Legal.

EFFECTIVENESS MEASURE

100% of sampled material-case evidence has a complete custody trail and matching integrity check.

ESCALATION THRESHOLD

Any unexplained custody gap, integrity mismatch or unauthorised repository access.

Management implication

The investigation lead opens an evidence register for every material case; trained custodians identify sources, create forensic copies or sealed originals, record

hashes/seal numbers, collector/time/location and every transfer, store evidence in access-controlled repositories, and escalate any custody break immediately to Legal

Material finding 3

INTERPRETATION

Domain Digital and Identity Fraud Risk D8-Q04	Materiality control_failure Priority 2070	Target period 60 days	Owner Chief Technology Officer
--	--	---	--

DIAGNOSIS

Privileged and administrator access governance was self-assessed as "Partially designed" (Some elements exist, but implementation is incomplete, inconsistent or not evidenced; normalised score 40/100). This is self-reported and requires the listed operating evidence before it can be treated as verified.

WHY IT MATTERS

This recorded weakness affects a methodology hard gate and must be remediated before relying on the aggregate maturity result.

FRAUD MECHANISM

Excess or unmanaged administrator rights allow records, controls and logs to be altered or concealed.

LIKELY IMPACTS

Direct -- compromised or privileged access can alter records and transactions.; Digital misuse can evade prevention and monitoring.

INTERPRETATION

Privileged and administrator access governance was self-assessed as "Partially designed" (Some elements exist, but implementation is incomplete, inconsistent or not evidenced; normalised score 40/100). This is self-reported and requires the listed operating evidence before it can be treated as verified.

RECOMMENDED CONTROL

IT Security maintains a complete privileged-account register, links each human and service account to an owner and approved justification, enforces separate named admin identities and MFA, records privileged sessions, and sends the full population quarterly to system owners and Risk for independent keep/remove certification; removals close within 24 hours for leavers and five business days otherwise.

EFFECTIVENESS MEASURE

100% privileged accounts recertified quarterly; leaver access removed within 24 hours; zero unjustified shared admin accounts.

ESCALATION THRESHOLD

Any unknown or unjustified privileged account, missed recertification or leaver access beyond 24 hours.

Material finding 4

INTERPRETATION

Domain	Materiality	Target period	Owner
Fraud Detection Capability D4-Q01	control_failure Priority 2020	90 days	CFO / COO

DIAGNOSIS

Transaction and activity monitoring was self-assessed as "Partially designed" (Some elements exist, but implementation is incomplete, inconsistent or not evidenced; normalised score 40/100). This is self-reported and requires the listed operating evidence before it can be treated as verified.

WHY IT MATTERS

This recorded weakness affects a methodology hard gate and must be remediated before relying on the aggregate maturity result.

FRAUD MECHANISM

Without deliberate monitoring, fraud is found only by accident, complaint or external notification, typically long after the loss has compounded.

LIKELY IMPACTS

Direct -- unreviewed exceptions can allow losses to compound.; Alert backlogs can conceal important anomalies.

INTERPRETATION

Transaction and activity monitoring was self-assessed as "Partially designed" (Some elements exist, but implementation is incomplete, inconsistent or not evidenced; normalised score 40/100). This is self-reported and requires the listed operating evidence before it can be treated as verified.

RECOMMENDED CONTROL

The monitoring owner must define red-flag indicators per material process — duplicate payments, round-value patterns, out-of-hours activity, unusual volume by user, adjustments reversing prior entries, and supplier or customer concentration — run them against the complete transaction population on a set rhythm, and route output into the exception queue with designated control owners and SLAs; coverage against the process fraud maps is reported to the fraud forum.

EFFECTIVENESS MEASURE

Monitoring covers all material processes on rhythm with reconciled population totals and routed output.

ESCALATION THRESHOLD

A material process unmonitored, or a monitoring cycle missed without escalation.

Management implication

The monitoring owner must define red-flag indicators per material process —

duplicate payments, round-value patterns, out-of-hours activity, unusual volume by

Material finding 5

INTERPRETATION

Domain Continuous Improvement and Fraud Risk Monitoring D10-Q01	Materiality control_failure Priority 1940	Target period 90 days	Owner CI Ma Di
--	--	---	--

DIAGNOSIS

Periodic fraud risk and control environment review was self-assessed as "Partially designed" (Some elements exist, but implementation is incomplete, inconsistent or not evidenced; normalised score 40/100). This is self-reported and requires the listed operating evidence before it can be treated as verified.

WHY IT MATTERS

This recorded weakness affects a methodology hard gate and must be remediated before relying on the aggregate maturity result.

FRAUD MECHANISM

Controls decay quietly through staff turnover, system change and workload pressure, so a control believed to be operating may have lapsed months earlier.

LIKELY IMPACTS

Impact requires case-specific validation.; Operating impact requires case-specific validation.

INTERPRETATION

Periodic fraud risk and control environment review was self-assessed as "Partially designed" (Some elements exist, but implementation is incomplete, inconsistent or not evidenced; normalised score 40/100). This is self-reported and requires the listed operating evidence before it can be treated as verified.

RECOMMENDED CONTROL

The Head of Risk must run a scheduled review that revisits the fraud risk assessment for continued relevance, confirms for each key control that it still has a named owner and is still operating by sampling recent evidence rather than accepting attestation, records any control that has lapsed or degraded, and reports a consolidated risk and control position to the governing body with owned remediation actions and due dates.

EFFECTIVENESS MEASURE

Every key control is evidence-tested within the review cycle, with lapses remediated by due date.

ESCALATION THRESHOLD

Review overdue, or a key control found lapsed with no remediation owner.

Material finding 6

INTERPRETATION

Domain	Materiality	Target period	Owner
Fraud Risk Identification D2-Q01	control_failure Priority 1940	90 days	CE Ma Di

DIAGNOSIS

Structured fraud risk assessment currency was self-assessed as "Partially designed" (Some elements exist, but implementation is incomplete, inconsistent or not evidenced; normalised score 40/100). This is self-reported and requires the listed operating evidence before it can be treated as verified.

WHY IT MATTERS

This recorded weakness affects a methodology hard gate and must be remediated before relying on the aggregate maturity result.

FRAUD MECHANISM

Without a current structured assessment, control investment follows intuition and recent events, leaving whole exposure areas unexamined and unfunded.

LIKELY IMPACTS

Impact requires case-specific validation.; Operating impact requires case-specific validation.

INTERPRETATION

Structured fraud risk assessment currency was self-assessed as "Partially designed" (Some elements exist, but implementation is incomplete, inconsistent or not evidenced; normalised score 40/100). This is self-reported and requires the listed operating evidence before it can be treated as verified.

RECOMMENDED CONTROL

The Head of Risk must run a documented fraud risk assessment at least every two years using a repeatable method: scope the material processes and channels, identify fraud scenarios per process with the roles able to execute them, rate likelihood and impact before and after existing controls, name a treatment owner and due date for every unacceptable residual risk, and obtain governing-body approval of the plan; assessment date, participants and method are retained.

EFFECTIVENESS MEASURE

A fraud risk assessment less than 24 months old covers all material processes with an approved, in-date treatment plan.

ESCALATION THRESHOLD

Assessment older than 24 months, or any unacceptable residual risk without a funded owner and due date.

Material finding 7

INTERPRETATION

Domain Digital and Identity Fraud Risk D8-Q01	Materiality control_failure Priority 1940	Target period 60 days	Owner COO / CFO
--	--	---	---------------------------------------

DIAGNOSIS

Identity verification at risk points was self-assessed as "Partially designed" (Some elements exist, but implementation is incomplete, inconsistent or not evidenced; normalised score 40/100). This is self-reported and requires the listed operating evidence before it can be treated as verified.

WHY IT MATTERS

This recorded weakness affects a methodology hard gate and must be remediated before relying on the aggregate maturity result.

FRAUD MECHANISM

An unverified or impersonated identity allows a fraudulent party to receive goods, payments, credit, benefits or system access under someone else's name.

LIKELY IMPACTS

Direct -- compromised or privileged access can alter records and transactions.; Digital misuse can evade prevention and monitoring.

INTERPRETATION

Identity verification at risk points was self-assessed as "Partially designed" (Some elements exist, but implementation is incomplete, inconsistent or not evidenced; normalised score 40/100). This is self-reported and requires the listed operating evidence before it can be treated as verified.

RECOMMENDED CONTROL

The process owner must define the risk points requiring verification — customer or beneficiary enrolment, employee onboarding, supplier activation and counterparty contracting — and apply proportionate checks against independent sources such as identity documents validated for authenticity, company registration records, and confirmation of contact details through independently obtained channels; results and evidence are retained under applicable data-protection obligations, exceptions require documented approval, and sensitive profile or banking changes trigger re-verification.

EFFECTIVENESS MEASURE

100% of in-scope enrolments and activations carry completed verification before activation, with all exceptions approved.

Organisation-specific scenario 1

INTERPRETATION

This is a plausible, conditional pathway—not an allegation or conclusion that the event occurred.

SCENARIO

Without deliberate monitoring, fraud is found only by accident, complaint or external notification, typically long after the loss has compounded

ACTOR / OPPORTUNITY

Fraud Detection Capability: Partially designed — Some elements exist, but implementation is incomplete, inconsistent or not evidenced.; self-assessed, not independently verified.

ENTRY POINT

The recorded control condition is engaged through Fraud Detection Capability: The organisation monitors transactions or operational activity for unusual patterns, anomalies or red flags.

MECHANISM

Misuse can occur when an actor exploits the recorded control condition and without deliberate monitoring, fraud is found only by accident, complaint or external notification, typically long after the loss has compounded.

CONTROL BYPASSED

Defined monitoring covers the material transaction and activity population, uses the named record indicators, and produces reviewable output on a set rhythm rather than relying on incidental discovery.

CONCEALMENT

The activity may appear routine until complete population review, independent approval or exception monitoring exposes it.

CONSEQUENCE

Direct -- unreviewed exceptions can allow losses to compound.; Alert backlogs can conceal important anomalies.

WARNING INDICATORS

A material process unmonitored, or a monitoring cycle missed without escalation.; An exception, access, approval or incident record that cannot be reconciled to the complete in-scope population.

IMMEDIATE CONTAINMENT

Escalate to CFO / COO, preserve relevant records and apply the control's escalation threshold: A material process unmonitored, or a monitoring cycle missed without escalation.

LONG-TERM RESPONSE

The monitoring owner must define red-flag indicators per material process — duplicate payments, round-value patterns, out-of-hours activity, unusual volume by user, adjustments reversing prior entries, and supplier or customer concentration — run them against the complete transaction population on a set rhythm, and route output into the exception queue with designated control owners and SLAs; coverage against the process fraud maps is reported to the fraud forum.

Scenario boundary

This is a plausible scenario derived from the organisation's self-assessment evidence. It is not an allegation that the event has occurred.

Organisation-specific scenario 2

INTERPRETATION

This is a plausible, conditional pathway—not an allegation or conclusion that the event occurred.

SCENARIO

Controls decay quietly through staff turnover, system change and workload pressure, so a control believed to be operating may have lapsed months earlier

ACTOR / OPPORTUNITY

Continuous Improvement and Fraud Risk Monitoring: Partially designed — Some elements exist, but implementation is incomplete, inconsistent or not evidenced.; self-assessed, not independently verified.

ENTRY POINT

The recorded control condition is engaged through Continuous Improvement and Fraud Risk Monitoring: The organisation periodically reviews its fraud risks and control environment.

MECHANISM

Misuse can occur when an actor exploits the recorded control condition and controls decay quietly through staff turnover, system change and workload pressure, so a control believed to be operating may have lapsed months earlier.

CONTROL BYPASSED

A scheduled review reassesses fraud risks, tests whether key controls still operate as designed, and reports a consolidated position with owned actions to governance.

CONCEALMENT

The activity may appear routine until complete population review, independent approval or exception monitoring exposes it.

CONSEQUENCE

Impact requires case-specific validation.; Operating impact requires case-specific validation.

WARNING INDICATORS

An exception, access, approval or incident record that cannot be reconciled to the complete in-scope population.; Review overdue, or a key control found lapsed with no remediation owner.

IMMEDIATE CONTAINMENT

Escalate to CEO / Managing Director, preserve relevant records and apply the control's escalation threshold: Review overdue, or a key control found lapsed with no remediation owner.

LONG-TERM RESPONSE

The Head of Risk must run a scheduled review that revisits the fraud risk assessment for continued relevance, confirms for each key control that it still has a named owner and is still operating by sampling recent evidence rather than accepting attestation, records any control that has lapsed or degraded, and reports a consolidated risk and control position to the governing body with owned remediation actions and due dates.

Scenario boundary

This is a plausible scenario derived from the organisation's self-assessment evidence. It is not an allegation that the event has occurred.

Organisation-specific scenario 3

INTERPRETATION

This is a plausible, conditional pathway—not an allegation or conclusion that the event occurred.

SCENARIO

Without a current structured assessment, control investment follows intuition and recent events, leaving whole exposure areas unexamined and unfunded

ACTOR / OPPORTUNITY

Fraud Risk Identification: Partially designed — Some elements exist, but implementation is incomplete, inconsistent or not evidenced.; self-assessed, not independently verified.

ENTRY POINT

The recorded control condition is engaged through Fraud Risk Identification: The organisation has completed a structured fraud risk assessment within the past two years.

MECHANISM

Misuse can occur when an actor exploits the recorded control condition and without a current structured assessment, control investment follows intuition and recent events, leaving whole exposure areas unexamined and unfunded.

CONTROL BYPASSED

A structured fraud risk assessment completed within the past two years covers the material processes, uses a repeatable method, rates inherent and residual risk, names owners and produces a tracked treatment plan.

CONCEALMENT

The activity may appear routine until complete population review, independent approval or exception monitoring exposes it.

CONSEQUENCE

Impact requires case-specific validation.; Operating impact requires case-specific validation.

WARNING INDICATORS

An exception, access, approval or incident record that cannot be reconciled to the complete in-scope population.; Assessment older than 24 months, or any unacceptable residual risk without a funded owner and due date.

IMMEDIATE CONTAINMENT

Escalate to CEO / Managing Director, preserve relevant records and apply the control's escalation threshold: Assessment older than 24 months, or any unacceptable residual risk without a funded owner and due date.

LONG-TERM RESPONSE

The Head of Risk must run a documented fraud risk assessment at least every two years using a repeatable method: scope the material processes and channels, identify fraud scenarios per process with the roles able to execute them, rate likelihood and impact before and after existing controls, name a treatment owner and due date for every unacceptable residual risk, and obtain governing-body approval of the plan; assessment date, participants and method are retained.

Scenario boundary

This is a plausible scenario derived from the organisation's self-assessment evidence. It is not an allegation that the event has occurred.

Organisation-specific scenario 4

INTERPRETATION

This is a plausible, conditional pathway—not an allegation or conclusion that the event occurred.

SCENARIO

Supplier activation without verification admits a fictitious or conflicted vendor

ACTOR / OPPORTUNITY

Digital and Identity Fraud Partially designed — Some elements exist, but implementation is incomplete, inconsistent or not evidenced.; self-assessed, not independently verified.

ENTRY POINT

A new or reactivated supplier progressing to payment before independent registration and ownership verification.

MECHANISM

Misuse can occur when an actor exploits the recorded control condition and an unverified or impersonated identity allows a fraudulent party to receive goods, payments, credit, benefits or system access under someone else’s name.

CONTROL BYPASSED

Identity verification is applied at defined risk points using independent sources proportionate to risk, with results recorded, exceptions approved and re-verification on sensitive change.

CONCEALMENT

The activity may appear routine until complete population review, independent approval or exception monitoring exposes it.

CONSEQUENCE

Direct -- compromised or privileged access can alter records and transactions.; Digital misuse can evade prevention and monitoring.

WARNING INDICATORS

Activation before verification, an unapproved exception, or a sensitive change without re-verification.; An exception, access, approval or incident record that cannot be reconciled to the complete in-scope population.

IMMEDIATE CONTAINMENT

Escalate to COO / CFO, preserve relevant records and apply the control's escalation threshold: Activation before verification, an unapproved exception, or a sensitive change without re-verification.

LONG-TERM RESPONSE

The process owner must define the risk points requiring verification — customer or beneficiary enrolment, employee onboarding, supplier activation and counterparty contracting — and apply proportionate checks against independent sources such as identity documents validated for authenticity, company registration records, and confirmation of contact details through independently obtained channels; results and evidence are retained under applicable data-protection obligations, exceptions require documented approval, and sensitive profile or banking changes trigger re-verification.

Scenario boundary

This is a plausible scenario derived from the organisation's self-assessment evidence. It is not an allegation that the event has occurred.

Priority exposure 1

INTERPRETATION

Priority	Likelihood	Impact	Target period
Critical	Moderate	Severe	60 days

RISK STATEMENT

Because privileged, administrator or sensitive-data access is not completely restricted, logged and independently recertified, there is a risk that a privileged user or compromised administrator identity alters records, controls or logs without timely detection. Consequence pathway: confidence in digital controls is damaged; critical systems and audit trails lose integrity; high-impact transactions or data can be manipulated; security and personal-data obligations may be breached.

CAUSE AND EVENT

privileged, administrator or sensitive-data access is not completely restricted, logged and independently recertified; a privileged user or compromised administrator identity alters records, controls or logs without timely detection

CURRENT CONTROL POSITION

Digital and Identity Fraud Partially designed — Some elements exist, but implementation is incomplete, inconsistent or not evidenced

REQUIRED TREATMENT

IT Security maintains a complete privileged-account register, links each human and service account to an owner and approved justification, enforces separate named admin identities and MFA, records privileged sessions, and sends the full population quarterly to system owners and Risk for independent keep/remove certification; removals close within 24 hours for leavers and five business days otherwise.

ACCOUNTABLE EXECUTIVE

Chief Technology Officer

PROCESS OWNER

Identity and Access Management

EFFECTIVENESS MEASURE

100% privileged accounts recertified quarterly; leaver access removed within 24 hours; zero unjustified shared admin accounts.

Priority exposure 2

INTERPRETATION

Priority	Likelihood	Impact	Target period
Critical	Moderate	Severe	90 days

RISK STATEMENT

Because the assessed control design or operation does not meet the exact expected standard, there is a risk that without deliberate monitoring, fraud is found only by accident, complaint or external notification, typically long after the loss has compounded. Consequence pathway: Alert backlogs can conceal important anomalies; unreviewed exceptions can allow losses to compound.

CAUSE AND EVENT

the assessed control design or operation does not meet the exact expected standard; without deliberate monitoring, fraud is found only by accident, complaint or external notification, typically long after the loss has compounded

CURRENT CONTROL POSITION

Fraud Detection Capability: Partially designed — Some elements exist, but implementation is incomplete, inconsistent or not evidenced

REQUIRED TREATMENT

The monitoring owner must define red-flag indicators per material process — duplicate payments, round-value patterns, out-of-hours activity, unusual volume by user, adjustments reversing prior entries, and supplier or customer concentration — run them against the complete transaction population on a set rhythm, and route output into the exception queue with designated control owners and SLAs; coverage against the process fraud maps is reported to the fraud forum.

ACCOUNTABLE EXECUTIVE

CFO / COO

PROCESS OWNER

Fraud monitoring owner

EFFECTIVENESS MEASURE

Monitoring covers all material processes on rhythm with reconciled population totals and routed output.

Priority exposure 3

INTERPRETATION

Priority	Likelihood	Impact	Target period
Critical	Moderate	Severe	90 days

RISK STATEMENT

Because the assessed control design or operation does not meet the exact expected standard, there is a risk that controls decay quietly through staff turnover, system change and workload pressure, so a control believed to be operating may have lapsed months earlier. Consequence pathway: Impact requires case-specific validation; Operating impact requires case-specific validation.

CAUSE AND EVENT

the assessed control design or operation does not meet the exact expected standard; controls decay quietly through staff turnover, system change and workload pressure, so a control believed to be operating may have lapsed months earlier

CURRENT CONTROL POSITION

Continuous Improvement and Fraud Risk Monitoring: Partially designed — Some elements exist, but implementation is incomplete, inconsistent or not evidenced

REQUIRED TREATMENT

The Head of Risk must run a scheduled review that revisits the fraud risk assessment for continued relevance, confirms for each key control that it still has a named owner and is still operating by sampling recent evidence rather than accepting attestation, records any control that has lapsed or degraded, and reports a consolidated risk and control position to the governing body with owned remediation actions and due dates.

ACCOUNTABLE EXECUTIVE

CEO / Managing Director

PROCESS OWNER

Head of Risk

EFFECTIVENESS MEASURE

Every key control is evidence-tested within the review cycle, with lapses remediated by due date.

Target control blueprint 1

A target-state blueprint is complete only when the operating design, ownership, proof and failure response are explicit.

CONTROL OBJECTIVE

Close the material control weakness recorded for "Management owns fraud risk, while internal audit or assurance functions provide independent review where they exist".

CURRENT STATE

Partially designed — Some elements exist, but implementation is incomplete, inconsistent or not evidenced.; self-assessed and not independently verified.

TARGET STATE

Management designs and operates fraud controls; internal audit or another independent function periodically tests them and reports without assuming management responsibility.

CONTROL DESIGN

The CEO and audit-committee chair must approve a RACI that assigns control operation to management and risk owners, reserves independent testing and unrestricted reporting for internal audit or equivalent assurance, and requires annual conflict review; the company secretary retains the approved RACI and minutes.

POPULATION

The complete in-scope population for annual mandate review and quarterly exception reporting must be reconciled before sampling.

FREQUENCY

Annual mandate review and quarterly exception reporting

ACCOUNTABLE EXECUTIVE

CEO / Managing Director

PROCESS OWNER

Head of Risk and business control owners

OVERSIGHT FUNCTION

Audit Committee / Internal Audit

PROOF RETAINED

Approved fraud-risk RACI; Audit-committee minutes showing independent reporting; Internal audit charter or assurance mandate

INDEPENDENT CHECK

No key fraud control is both operated and independently certified by the same accountable function.

ESCALATION / FAILURE RESPONSE

Any assurance reviewer assigned operational ownership of the control under review.; Escalate exceptions through the defined owner and oversight route.

Target control blueprint 2

A target-state blueprint is complete only when the operating design, ownership, proof and failure response are explicit.

CONTROL OBJECTIVE

Close the material control weakness recorded for "Evidence linked to suspected fraud is identified, preserved and handled appropriately".

CURRENT STATE

Partially designed — Some elements exist, but implementation is incomplete, inconsistent or not evidenced.; self-assessed and not independently verified.

TARGET STATE

Evidence is collected under legal direction where needed, hashed or sealed, logged through every transfer, access-restricted and retained under an approved schedule.

CONTROL DESIGN

The investigation lead opens an evidence register for every material case; trained custodians identify sources, create forensic copies or sealed originals, record hashes/seal numbers, collector/time/location and every transfer, store evidence in access-controlled repositories, and escalate any custody break immediately to Legal.

POPULATION

The complete in-scope population for at collection and every transfer; quarterly custody-log review must be reconciled before sampling.

FREQUENCY

At collection and every transfer; quarterly custody-log review

ACCOUNTABLE EXECUTIVE

General Counsel / COO

PROCESS OWNER

Investigation lead / Evidence custodian

OVERSIGHT FUNCTION

Legal / Compliance

PROOF RETAINED

Chain-of-custody forms; Evidence register; Hash or seal records; Repository access log; Retention/legal-hold instruction

INDEPENDENT CHECK

100% of sampled material-case evidence has a complete custody trail and matching integrity check.

ESCALATION / FAILURE RESPONSE

Any unexplained custody gap, integrity mismatch or unauthorised repository access.; Escalate exceptions through the defined owner and oversight route.

Target control blueprint 3

A target-state blueprint is complete only when the operating design, ownership, proof and failure response are explicit.

CONTROL OBJECTIVE

Close the material control weakness recorded for "Access to sensitive digital systems, administrator rights and confidential data is restricted and reviewed".

CURRENT STATE

Partially designed — Some elements exist, but implementation is incomplete, inconsistent or not evidenced.; self-assessed and not independently verified.

TARGET STATE

Every privileged account is named, justified, least-privileged, strongly authenticated, logged and independently recertified quarterly; emergency access expires automatically.

CONTROL DESIGN

IT Security maintains a complete privileged-account register, links each human and service account to an owner and approved justification, enforces separate named admin identities and MFA, records privileged sessions, and sends the full population quarterly to system owners and Risk for independent keep/remove certification; removals close within 24 hours for leavers and five business days otherwise.

POPULATION

The complete in-scope population for continuous logging; quarterly recertification; event-driven removal must be reconciled before sampling.

FREQUENCY

Continuous logging; quarterly recertification; event-driven removal

ACCOUNTABLE EXECUTIVE

Chief Technology Officer

PROCESS OWNER

Identity and Access Management

OVERSIGHT FUNCTION

Information Security / Internal Audit

PROOF RETAINED

Approval and business justification; Privileged-account register; Privileged-session/access logs; Quarterly independent recertification; Removal tickets

INDEPENDENT CHECK

100% privileged accounts recertified quarterly; leaver access removed within 24 hours; zero unjustified shared admin accounts.

ESCALATION / FAILURE RESPONSE

Any unknown or unjustified privileged account, missed recertification or leaver access beyond 24 hours.; Escalate exceptions through the defined owner and oversight route.

Target control blueprint 4

A target-state blueprint is complete only when the operating design, ownership, proof and failure response are explicit.

CONTROL OBJECTIVE

Close the material control weakness recorded for "The organisation monitors transactions or operational activity for unusual patterns, anomalies or red flags".

CURRENT STATE

Partially designed — Some elements exist, but implementation is incomplete, inconsistent or not evidenced.; self-assessed and not independently verified.

TARGET STATE

Defined monitoring covers the material transaction and activity population, uses the named record indicators, and produces reviewable output on a set rhythm rather than relying on incidental discovery.

CONTROL DESIGN

The monitoring owner must define red-flag indicators per material process — duplicate payments, round-value patterns, out-of-hours activity, unusual volume by user, adjustments reversing prior entries, and supplier or customer concentration — run them against the complete transaction population on a set rhythm, and route output into the exception queue with designated control owners and SLAs; coverage against the process fraud maps is reported to the fraud forum.

POPULATION

The complete in-scope population for defined monitoring rhythm, at minimum monthly, with continuous capture must be reconciled before sampling.

FREQUENCY

Defined monitoring rhythm, at minimum monthly, with continuous capture

ACCOUNTABLE EXECUTIVE

CFO / COO

PROCESS OWNER

Fraud monitoring owner

OVERSIGHT FUNCTION

Head of Risk

PROOF RETAINED

Coverage report against process fraud maps; Monitoring output for recent periods; Population reconciliation to source systems; Red-flag indicator definitions per process

INDEPENDENT CHECK

Monitoring covers all material processes on rhythm with reconciled population totals and routed output.

ESCALATION / FAILURE RESPONSE

A material process unmonitored, or a monitoring cycle missed without escalation.; Escalate exceptions through the defined owner and oversight route.

Target control blueprint 5

A target-state blueprint is complete only when the operating design, ownership, proof and failure response are explicit.

CONTROL OBJECTIVE

Close the material control weakness recorded for "The organisation periodically reviews its fraud risks and control environment".

CURRENT STATE

Partially designed — Some elements exist, but implementation is incomplete, inconsistent or not evidenced.; self-assessed and not independently verified.

TARGET STATE

A scheduled review reassesses fraud risks, tests whether key controls still operate as designed, and reports a consolidated position with owned actions to governance.

CONTROL DESIGN

The Head of Risk must run a scheduled review that revisits the fraud risk assessment for continued relevance, confirms for each key control that it still has a named owner and is still operating by sampling recent evidence rather than accepting attestation, records any control that has lapsed or degraded, and reports a consolidated risk and control position to the governing body with owned remediation actions and due dates.

POPULATION

The complete in-scope population for at least annually, and after any material incident or restructuring must be reconciled before sampling.

FREQUENCY

At least annually, and after any material incident or restructuring

ACCOUNTABLE EXECUTIVE

CEO / Managing Director

PROCESS OWNER

Head of Risk

OVERSIGHT FUNCTION

Audit Committee / Board

PROOF RETAINED

Consolidated report to governance with actions and due dates; Key control operating evidence sampled in the period; Lapsed or degraded control register; Review scope and schedule

INDEPENDENT CHECK

Every key control is evidence-tested within the review cycle, with lapses remediated by due date.

ESCALATION / FAILURE RESPONSE

Review overdue, or a key control found lapsed with no remediation owner.; Escalate exceptions through the defined owner and oversight route.

Target operating model

The target operating model connects the control owner, process owner, oversight function and management information cycle.

Understand

Maintain the risk and scenario universe as processes, channels and data change.

Decide

Use explicit options, trade-offs, owner and target period for each leadership choice.

Build and monitor

Retain proof of completion, measure effectiveness and escalate failures through the agreed route.

ROLE	PRIMARY RESPONSIBILITY	MANAGEMENT INFORMATION
Accountable executive	Own the target state and accept or treat residual risk.	Action ageing, risk movement, decision status
Process owner	Operate the control and retain the defined proof.	Population, exceptions, SLA and failure response
Oversight function	Challenge design, quality and effectiveness.	Trend, thematic exceptions and escalation

Governance rhythm and functional responsibilities

A repeatable rhythm turns control design into management oversight.

CADENCE	FOCUS	REQUIRED OUTPUT
Monthly	Priority alerts, exceptions, population completeness and action ageing.	Owner-level action and escalation view
Quarterly	Risk refresh, scenario indicators, control-design dependencies and residual risk.	Management information pack with challenge
Board checkpoint	Leadership decisions, critical exposure, overdue actions and effectiveness measures.	Decision record and next checkpoint

Functional responsibility

Finance, Operations, Technology, Information Security, Risk, Procurement, People and Legal should each have a named contribution where the analytical universe links them to a priority control.

Leadership decisions and trade-offs

The decision library gives management three viable paths and makes trade-offs visible before selection.

Accountable Executive Mandate

DECISION REQUIRED

Approve accountable executive mandates and escalation authority for priority remediation.

OPTIONS AND TRADE-OFFS

Option A: Option A — deliver through existing internal ownership

Cost: Internal capacity and management time. · Benefit: Builds durable ownership inside the organisation. · Trade-off: May move more slowly where capability is immature.

Option B: Option B — use bounded specialist support

Cost: Targeted specialist budget and handover effort. · Benefit: Adds focused capacity against the named priority. · Trade-off: Requires clear scope, procurement and transfer of ownership.

Option C: Option C — combine internal ownership with targeted specialist support

Cost: Combined internal capacity plus targeted specialist budget. · Benefit: Keeps accountability internal while accelerating the priority design. · Trade-off: Needs explicit boundaries so ownership and escalation are not diluted.

DETERMINISTIC RECOMMENDATION

Name one accountable executive per linked control and approve a 30-day escalation route.

RECOMMENDATION RATIONALE

The recorded assessment links this decision to 8 material finding(s) and 8 risk(s). Management should confirm the final route, cost and delivery capacity.

OWNER / TARGET

CEO / Managing Director · 30 days

CONSEQUENCE OF DELAY

Priority controls remain ownerless or blocked and the maturity reading remains constrained.

Risk Acceptance Or Remediation

DECISION REQUIRED

Choose and record remediation rather than passive acceptance for Critical and High risks.

OPTIONS AND TRADE-OFFS

Option A: Option A — deliver through existing internal ownership

Cost: Internal capacity and management time. · Benefit: Builds durable ownership inside the organisation. · Trade-off: May move more slowly where capability is immature.

Option B: Option B — use bounded specialist support

Cost: Targeted specialist budget and handover effort. · Benefit: Adds focused capacity against the named priority. · Trade-off: Requires clear scope, procurement and transfer of ownership.

First 30 days

First 30 days is a design and implementation horizon. Completion requires a defined owner, deliverable, proof requirement and effectiveness measure.

First 30 days	Dependencies	Proof of completion	Failure response
• Apply immediate escalation at "Any assurance reviewer assigned operational ownership of the control under review." and deliver the exact control design: The CEO and audit-committee chair must approve a RACI that assigns control operation to management and risk owners, reserves independent testing and unrestricted reporting for internal audit or equivalent assurance, and requires annual conflict review; the company secretary retains the approved RACI and minutes.	Confirm data, ownership, funding and process dependencies.	• Approved fraud-risk RACI; Audit-committee minutes showing independent reporting; Internal audit charter or assurance mandate • Evidence of alternate route bypassing implicated management; Quarterly escalation timeliness review; Training completion records; Written escalation criteria and routes • Awareness test or survey results; Distribution evidence covering non-desk and contract staff; Published reporting route material;	• Any assurance reviewer assigned operational ownership of the control under review. • A qualifying matter escalated late, or an escalation routed only through an implicated manager. • Any site or worker group below the awareness threshold, or reporting material not reaching non-desk staff.

Days 31–90

Days 31–90 is a design and implementation horizon. Completion requires a defined owner, deliverable, proof requirement and effectiveness measure.

Days 31–90	Dependencies	Proof of completion	Failure response
• Apply immediate escalation at "Any unknown or unjustified privileged account, missed recertification or leaver access beyond 24 hours." and deliver the exact control design: IT Security maintains a complete privileged-account register, links each human and service account to an owner and approved justification, enforces separate named admin identities and MFA, records privileged sessions, and sends the full population quarterly to system owners and Risk for independent keep/remove certification; removals close within 24 hours for leavers and five business days otherwise. · owner: Chief Technology Officer · measure: 100% privileged accounts recertified quarterly; leaver access removed within 24 hours; zero unjustified shared	Confirm data, ownership, funding and process dependencies.	• Approval and business justification; Privileged-account register; Privileged-session/access logs; Quarterly independent recertification; Removal tickets • Defined verification risk points and required checks; Exception approvals; re-verification records for sensitive changes; Verification records with source and date • Chain-of-custody forms; Evidence register; Hash or seal records; Repository access log; Retention/legal-hold instruction • Alert investigation	• Any unknown or unjustified privileged account, missed recertification or leaver access beyond 24 hours. • Activation before verification, an unapproved exception, or a sensitive change without re-verification. • Any unexplained custody gap, integrity mismatch or unauthorised repository access. • Any high-risk alert unassigned after one business day or SLA breach rate above 5%. • A threat materialising

Months 4–6

Months 4–6 is a design and implementation horizon. Completion requires a defined owner, deliverable, proof requirement and effectiveness measure.

Months 4–6 • Apply immediate escalation at "Activation before verification, an unapproved exception, or a sensitive change without re-verification." and deliver the exact control design: The process owner must define the risk points requiring verification — customer or beneficiary enrolment, employee onboarding, supplier activation and counterparty contracting — and apply proportionate checks against independent sources such as identity documents validated for authenticity, company registration records, and confirmation of contact details through independently obtained channels; results and evidence are retained under applicable data-protection obligations, exceptions require documented	Dependencies Confirm data, ownership, funding and process dependencies.	Proof of completion • Defined verification risk points and required checks; Exception approvals; re-verification records for sensitive changes; Verification records with source and date • Chain-of-custody forms; Evidence register; Hash or seal records; Repository access log; Retention/legal-hold instruction • Alert investigation log; Disposition evidence; Exception population and control totals; Monthly quality-review sample • Control reviews or accept decisions arising; Named source list with assigned	Failure response • Activation before verification, an unapproved exception, or a sensitive change without re-verification. • Any unexplained custody gap, integrity mismatch or unauthorised repository access. • Any high-risk alert unassigned after one business day or SLA breach rate above 5%. • A threat materialising as a loss after being logged without a decision, or a missed monitoring cycle.
---	---	---	--

Months 7–12

Months 7–12 is a design and implementation horizon. Completion requires a defined owner, deliverable, proof requirement and effectiveness measure.

Months 7–12	Dependencies	Proof of completion	Failure response
• Apply immediate escalation at "Activation before verification, an unapproved exception, or a sensitive change without re-verification." and deliver the exact control design: The process owner must define the risk points requiring verification — customer or beneficiary enrolment, employee onboarding, supplier activation and counterparty contracting — and apply proportionate checks against independent sources such as identity documents validated for authenticity, company registration records, and confirmation of contact details through independently obtained channels; results and evidence are retained under applicable data-protection obligations, exceptions require documented	Confirm data, ownership, funding and process dependencies.	• Defined verification risk points and required checks; Exception approvals; re-verification records for sensitive changes; Verification records with source and date • Chain-of-custody forms; Evidence register; Hash or seal records; Repository access log; Retention/legal-hold instruction • Alert investigation log; Disposition evidence; Exception population and control totals; Monthly quality-review sample • Control reviews or accept decisions arising; Named source list with assigned	• Activation before verification, an unapproved exception, or a sensitive change without re-verification. • Any unexplained custody gap, integrity mismatch or unauthorised repository access. • Any high-risk alert unassigned after one business day or SLA breach rate above 5%. • A threat materialising as a loss after being logged without a decision, or a missed monitoring cycle.

Management scorecard

The scorecard keeps the target state visible after the initial build period.

MEASURE	OWNER	FREQUENCY	ESCALATION TRIGGER
Readiness and exposure movement	Accountable executive	Quarterly	Material deterioration or cap event
Priority control completion	Process owner	Monthly	Overdue critical action
Population completeness and exception ageing	Control owner	Monthly	Missing population or SLA breach
Effectiveness measure	Oversight function	Quarterly	Failure of defined effectiveness test
Decision and residual-risk status	Management committee	Quarterly	Decision past target period or risk not treated

Scorecard rule

Every measure must have a population, frequency, owner, threshold, escalation recipient and response.

Conclusion and route forward

The route forward is explicit: confirm the priority decisions, assign owners, build the target controls, retain proof and bring the scorecard to the next checkpoint.

Immediate management actions

- Apply immediate escalation at "Any assurance reviewer assigned operational ownership of the control under review." and deliver the exact control design: The CEO and audit-committee chair must approve a RACI that assigns control operation to management and risk owners, reserves independent testing and unrestricted reporting for internal audit or equivalent assurance, and requires annual conflict review; the company secretary retains the approved RACI and minutes. — CEO / Managing Director
- Apply immediate escalation at "A qualifying matter escalated late, or an escalation routed only through an implicated manager." and deliver the exact control design: The Head of Risk must publish escalation criteria defining what must be escalated, to whom and within what time, grant monitoring staff explicit authority to escalate directly to the fraud-risk executive or audit-committee chair where a manager is implicated, protect escalators from retaliation, train the monitoring team annually, and review escalation timeliness against criteria each quarter. — Head of Risk
- Apply immediate escalation at "Any site or worker group below the awareness threshold, or reporting material not reaching non-desk staff." and deliver the exact control design: The ethics owner must publish reporting routes in plain language across the channels the workforce actually uses — induction packs, payslip inserts, notice boards at depots and sites, intranet and supervisor briefings covering line manager, confidential channel and conflict-free

Next checkpoint

DECISION OWNER

CEO / Managing Director

TARGET PERIOD

30 days

FIRST DELIVERABLE

Signed mandate with decision rights, owners and escalation cadence.

BASIS

This report provides strategic fraud-risk analysis and control design based on management's recorded Fraud Readiness assessment responses. It does not independently verify operating effectiveness.